

Security Groups & NACLs

Your VPC's Two-Layer Firewall System

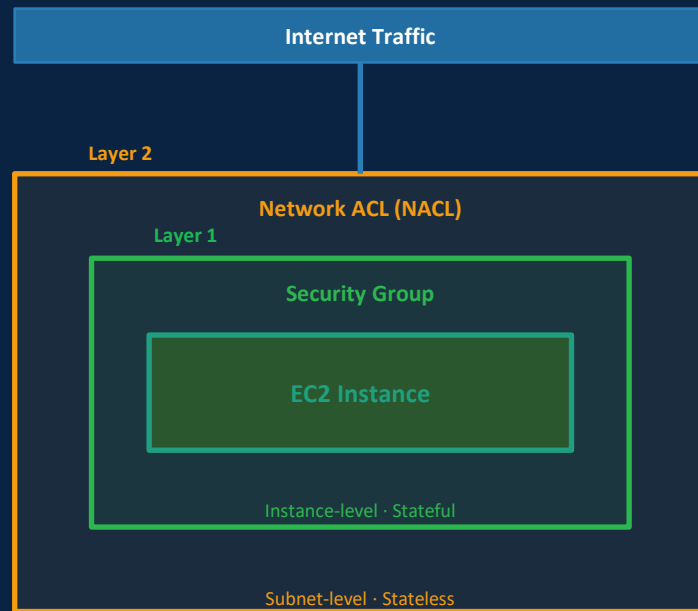
BaseStack Academy · AWS Cloud Accelerator

Networking & VPC

Cohort 1

Beginner-Friendly

SAA-C03 Aligned



1 Overview — Your VPC Has Two Firewall Layers

FOUNDATION

2 Security Groups — Rules, Stateful Behaviour & SG Referencing

CORE KNOWLEDGE

3 NACLs — Rules, Numbering, Stateless & Ephemeral Ports

DEEPER LEARNING

4 How It Works — Traffic Flow Through Both Layers

MECHANICS

5 Technical Deep Dive — SG vs NACL Side-by-Side

ADVANCED DETAIL

6 Architecture & Visual Model — Layered Defence

VISUAL

7 Real-World Nigerian Scenario

CONTEXT

8 Common Mistakes & Exam Traps

EXAM PREP

Overview — Your VPC Has Two Firewall Layers

AWS gives you two completely separate mechanisms to control traffic in your VPC. They work at different levels, they behave differently, and they are both needed for a production-grade security setup.

The first is the Security Group — it acts like a bouncer at the door of each individual EC2 instance, RDS database, or Lambda function. It checks every connection before letting it through.

The second is the Network Access Control List — or NACL — it acts like security at the gate of an entire neighbourhood. It checks traffic entering and leaving the whole subnet before it even reaches any individual resource.

The most important distinction — and the one the SAA-C03 exam tests constantly — is that Security Groups are stateful and NACLs are stateless. Understanding what that means, and why it changes how you write rules, is the core of today's lesson.

WHY NOW?

In 2023, one of the most common cloud misconfigurations in Nigerian fintechs was an overly permissive Security Group — specifically, inbound rules allowing 0.0.0.0/0 on port 22 (SSH) or port 3306 (MySQL). This exposed production databases and servers directly to the public internet.

SAA-C03 Domain 2 (Secure Architectures) tests Security Group and NACL configuration in almost every exam attempt. The stateful vs stateless distinction appears in at least 2-3 questions.

In every cloud engineering interview: 'How would you restrict a database so only your application server can reach it?' is a Security Group referencing question.

Beginner Note

Security Group = the bouncer at each person's apartment door. NACL = the security desk in the building lobby. Traffic passes through the lobby first (NACL), then the apartment door (Security Group). Both must allow it.

Security Groups — Rules, Stateful Behaviour & SG Referencing

Security Group Rule Anatomy

Type	Protocol	Port	Source	Action	Description
SSH	TCP	22	10.0.100.0/28	ALLOW	Bastion only
HTTPS	TCP	443	0.0.0.0/0	ALLOW	ALB inbound
Custom	TCP	5432	sg-app-servers	ALLOW	App SG ref
All	All	All	—	DENY *	Deny all else

Stateful — Return Traffic Is Automatic

If you allow inbound traffic, the RESPONSE is automatically allowed outbound — without you writing an outbound rule for it. Security Groups track connection state.

Example: You allow inbound TCP 443. A user connects. The response automatically flows back. You do NOT need an outbound rule for port 443.

SG Referencing — The Secure Database Pattern

Instead of using an IP address as the source, you can use another Security Group ID as the source. This is one of the most powerful Security Group features.



Why this is better than using an IP: IPs change. If an EC2 instance scales out, the new instance's IP also belongs to sg-app-servers, so it automatically gets database access without changing any rules.

Security Group Defaults — Know These Cold

Default Inbound:	DENY ALL — nothing enters until you add Allow rules
Default Outbound:	ALLOW ALL — all outbound traffic is permitted by default
Rule type:	Allow rules ONLY — you cannot add explicit Deny rules
Evaluation:	ALL rules evaluated — most permissive match wins

One SG, Many Resources

You can attach the same Security Group to multiple EC2 instances, RDS databases, and other resources. They all share the same rules. When you add a rule, all resources in that SG get it instantly — without touching each one individually.

Network ACLs — Rules, Numbering & The Ephemeral Port Trap

NACL Rule Anatomy — Inbound Rules (Custom NACL Example)

#	Protocol	Port	Source	Action	Notes
100	TCP	443	0.0.0.0/0	ALLOW	HTTPS inbound
110	TCP	80	0.0.0.0/0	ALLOW	HTTP inbound
120	TCP	1024-65535	0.0.0.0/0	ALLOW	EPHEMERAL!
*	All	All	0.0.0.0/0	DENY	Implicit deny

Ephemeral Ports — The Most Common NACL Mistake

When a client connects to a server, the client's operating system picks a random temporary port between 1024 and 65535 for the RESPONSE to come back on. This is the ephemeral port. Because NACLs are STATELESS — they do not remember connections — you must EXPLICITLY allow outbound traffic on ports 1024-65535 (for responses going OUT) AND inbound traffic on ports 1024-65535 (for responses coming IN).

Security Groups do NOT have this problem — they are stateful and handle return traffic automatically.

NACL Key Behaviours — Default vs Custom

Default NACL (Created with VPC)

ALLOWS all inbound AND all outbound by default. Every subnet in the VPC uses this until you create a custom one. Looks safe — but actually does nothing for security.

Default = ALLOW ALL. A false sense of security.

Custom NACL (You Create It)

DENIES all inbound AND all outbound by default. Only the * implicit deny rule exists. You must explicitly add Allow rules for everything you want to permit.

Custom = DENY ALL by default. Start from zero.

Rule Number Order — First Match Wins

NACL rules are evaluated in number order — lowest number first. The FIRST matching rule wins. If Rule 100 allows port 80 and Rule 200 denies port 80 — traffic on port 80 is ALLOWED.

Convention: Use 100, 200, 300... (gaps let you insert rules later).

How It Works — Traffic Flow Through Both Security Layers

1

Traffic Hits the NACL First (Subnet Level)

When a packet arrives at your subnet boundary — inbound traffic FROM the internet or FROM another subnet — the NACL evaluates it first. The NACL checks its numbered rules in order. If a matching Allow rule exists, the traffic enters the subnet. If no rule matches before the implicit * DENY, the traffic is dropped before it even reaches any EC2 instance.

Key: this evaluation happens for EVERY packet independently, because NACLs are stateless. The NACL does not remember that it allowed a previous packet in the same connection.

2

Traffic Reaches the Security Group (Instance Level)

If the NACL allowed the packet into the subnet, it then reaches the Security Group attached to the specific EC2 instance, RDS database, or Lambda function. The Security Group evaluates all its inbound rules simultaneously (not in order like NACLs). If ANY rule allows the traffic, it passes. If no rule allows it, it is dropped.

Key: because Security Groups are stateful, once an inbound connection is established, the outbound response is automatically allowed — even if you have no matching outbound rule.

3

Return Traffic — Where Stateful vs Stateless Matters Most

Inbound request is processed. Response needs to go back to the client. For the Security Group: automatic. The SG remembers the connection and allows the response without any outbound rule.

For the NACL: NOT automatic. The response must match an explicit ALLOW rule on the outbound side. This is why you MUST add outbound Allow rules for ports 1024-65535 (ephemeral ports) on any NACL. Without it, the response is silently dropped at the subnet boundary and the client sees a timeout — even though both the Security Group inbound rule and the NACL inbound rule allowed the original request.

Technical Deep Dive — Security Group vs NACL: Every Difference

This comparison is the most exam-tested table in VPC security. Know every row.

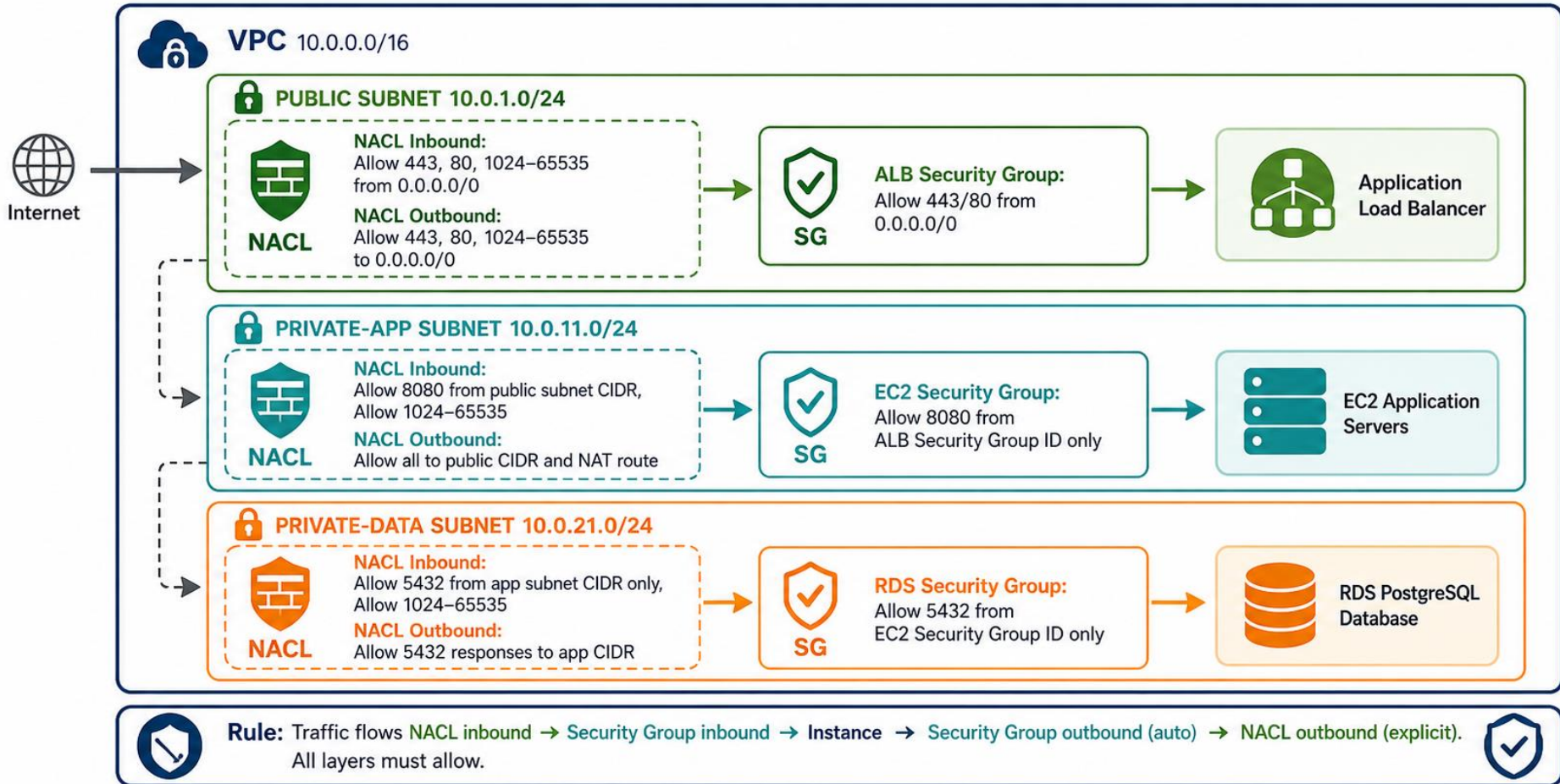
Feature	Security Group	Network ACL (NACL)
Operates at	EC2 instance / ENI (resource level)	Subnet boundary (all resources in subnet)
State	STATEFUL — return traffic automatic	STATELESS — must explicitly allow both directions
Rule types	Allow rules ONLY — no explicit Deny	Allow AND Deny rules
Rule evaluation	ALL rules evaluated — most permissive wins	Number order — FIRST match wins and stops
Default (new VPC)	Default SG: allow all within SG, deny all else	Default NACL: allow ALL inbound and outbound
Custom (you create)	New SG: deny all inbound, allow all outbound	New custom NACL: deny ALL (only * rule exists)
Ephemeral ports	Not needed — stateful handles return traffic	REQUIRED: allow 1024-65535 for responses
Scope	One or more specific instances	Entire subnet — all resources affected
Can source/dest be a SG ID?	YES — SG referencing (best practice)	NO — must use CIDR blocks only
Best use case	Primary security layer — instance traffic control	Secondary defence — block specific IPs/CIDRs at subnet
AWS recommendation	Use SGs as primary control for all resources	Use NACLs as additional layer for subnet-wide rules

SG: Stateful · Allow only · Most permissive wins · Instance-level

NACL: Stateless · Allow+Deny · First match wins · Subnet-level · Needs ephemeral ports

Architecture — Layered Security Across the 3-Tier VPC

Traffic must pass through the NACL at the subnet boundary and the Security Group at the instance. Both must allow.



Real-World Nigerian Scenario — Interswitch Payment Gateway Hardening

SCENARIO: An Interswitch-style payment gateway processes card transactions for Nigerian merchants. A PCI-DSS audit flagged three security misconfigurations in their AWS VPC. The security team must fix Security Group and NACL configurations before their next quarterly review. Each finding represents a real-world mistake made by Nigerian cloud teams.

Audit Findings, Root Cause & Correct Fix

FINDING 1: SSH (Port 22) Open to 0.0.0.0/0 on ALL EC2 Instances

The EC2 Security Group inbound rules included: Type SSH · TCP · 22 · Source 0.0.0.0/0. Every EC2 instance in the production environment — including app servers and backend APIs — was directly accessible via SSH from any IP address on the internet. A brute-force SSH scanner from Eastern Europe had already made 14,000 login attempts in 48 hours (visible in VPC Flow Logs).

FIX:

Remove the 0.0.0.0/0 SSH rule immediately. Add a new inbound rule: SSH · TCP · 22 · Source: sg-bastion (the Bastion Host Security Group ID). Now ONLY the Bastion Host can initiate SSH to other instances. Engineers SSH to the Bastion first, then jump to internal servers. External attackers cannot reach any internal instance directly.

FINDING 2: RDS Database Allowed All Traffic from the Entire VPC CIDR

The RDS PostgreSQL Security Group had: TCP · 5432 · Source 10.0.0.0/16. This means any EC2 instance in ANY subnet across the ENTIRE VPC — including developer laptops connected via VPN, test environments, and monitoring servers — could query the production payment database directly. PCI-DSS Requirement 1 mandates that access to cardholder data systems is restricted to only what is needed.

FIX:

Replace the VPC CIDR source with a Security Group reference: TCP · 5432 · Source: sg-app-servers. Now ONLY EC2 instances that belong to the application server Security Group can query the database. Even if a developer's compromised laptop is on the VPN, it cannot reach the RDS database — because the laptop is not in sg-app-servers.

FINDING 3: Custom NACL on Data Subnet Was Silently Dropping Responses

The security team had correctly created a custom NACL on the data subnet, allowing inbound port 5432 from the app subnet CIDR. But after deployment, the application started throwing intermittent database connection timeouts. The queries were reaching RDS, but responses were being dropped. VPC Flow Logs showed REJECT entries on outbound traffic from the data subnet.

FIX:

The custom NACL had no outbound rules — custom NACLs start with DENY ALL. The database's TCP responses were being sent back on ephemeral ports (1024-65535), but the NACL outbound rules didn't allow those ports. Added: Outbound NACL Rule 100: TCP · 1024-65535 · Destination: app subnet CIDR · ALLOW. Timeouts immediately resolved. This is the classic stateless NACL ephemeral port mistake.

Discussion: Why did Finding 3 cause intermittent timeouts rather than a complete connection failure? What does that tell you about how TCP uses ephemeral ports?

Common Mistakes & Exam Traps

These are the most common SAA-C03 exam errors on Security Groups & NACLs — every one costs marks.

X TRAP 1: Security Groups have NO explicit DENY option — you can only add Allow rules. NACLs have both Allow and Deny.

A common distractor: 'Add a Deny rule to the Security Group to block a specific attacker IP.' You CANNOT add a Deny rule to a Security Group. If you need to block a specific IP address, you use a NACL Deny rule on the subnet. Security Groups work on the assumption that everything not explicitly allowed is implicitly denied — but you cannot add an explicit deny.

X TRAP 2: NACLs evaluate rules in NUMBER ORDER — lower numbers first. A Deny rule with a LOWER number than an Allow rule will BLOCK traffic.

Example: NACL Rule 90: Deny TCP 443 from 0.0.0.0/0. Rule 100: Allow TCP 443 from 0.0.0.0/0. Traffic on port 443 is DENIED — because Rule 90 (lower number) is evaluated first and wins. The Allow at Rule 100 is never reached. This evaluation order is the opposite of Security Groups, which evaluate ALL rules simultaneously.

X TRAP 3: Custom NACLs start with DENY ALL — the default NACL allows all. They look the same in the console until you check the rules.

When you create a custom NACL, it starts with only the implicit * DENY rule. NOTHING is allowed. You must add all Allow rules yourself — including the ephemeral port range for responses. Many teams create a custom NACL thinking it works like the default, deploy it, and wonder why all traffic immediately stops working.

X TRAP 4: NACLs are STATELESS — you must explicitly allow BOTH directions, including ephemeral ports 1024-65535.

If you allow inbound HTTPS (port 443), the response goes back on a random ephemeral port (1024-65535). If your NACL outbound rules do not include port range 1024-65535, the response is dropped. Traffic appears to arrive (the request made it in) but the connection times out because the response cannot leave. Security Groups never have this problem — they are stateful.

X TRAP 5: When troubleshooting connectivity, check BOTH the Security Group AND the NACL. Both must allow for traffic to pass.

A packet is dropped if either the NACL or the Security Group rejects it. If a connection is failing and your Security Group looks correct, check the NACL on the subnet — especially custom NACLs missing outbound ephemeral port rules. Use VPC Flow Logs to see ACCEPT vs REJECT decisions at each layer.

Question

A solutions architect at a Lagos fintech has set up a VPC with a public subnet and a private subnet. The private subnet has a custom NACL applied. An EC2 application server in the public subnet needs to connect to an RDS database in the private subnet on port 5432. The security team has added the following rules to the private subnet's custom NACL:

Inbound Rule 100: Allow TCP 5432 from 10.0.1.0/24 (public subnet CIDR)

Outbound Rule 100: Allow TCP 5432 to 10.0.1.0/24

Developers report that the EC2 server cannot connect to the database. The RDS Security Group correctly allows port 5432 from the EC2 instance's Security Group. Which change will fix the connectivity issue?

A

Add an inbound NACL rule allowing TCP port 5432 from 0.0.0.0/0, to ensure all sources can reach the database.

Wrong. The inbound rule for port 5432 from the public subnet already exists (Rule 100). Allowing 0.0.0.0/0 would be a security violation and does not fix the actual problem.

B

Add an outbound NACL rule allowing TCP ports 1024-65535 to 10.0.1.0/24 (the ephemeral port range).

CORRECT

Correct. The NACL is stateless. When RDS responds to the EC2 connection, the response goes back on a random ephemeral port (1024-65535). The current outbound rule only allows port 5432 outbound — not the ephemeral range. The response is being dropped. Adding ephemeral ports outbound fixes this.

C

Remove the custom NACL from the private subnet and rely on the default NACL instead.

Wrong. The default NACL allows all traffic which would work, but it removes all subnet-level security controls — an incorrect approach. The fix should preserve security while enabling connectivity.

D

Add an inbound Security Group rule on the RDS instance allowing TCP 5432 from 0.0.0.0/0.

Wrong. The Security Group is already correctly configured (allows port 5432 from the EC2 SG). The problem is in the NACL, not the Security Group. Opening 0.0.0.0/0 is also a security anti-pattern.

E

Change the RDS Security Group to allow inbound traffic from the public subnet CIDR 10.0.1.0/24 instead of the EC2 Security Group ID.

Wrong. The Security Group is working correctly and referencing the EC2 SG ID is the correct secure pattern. Switching to a CIDR is less secure. The problem is the NACL missing ephemeral port outbound rules.

Key Takeaways — What You Learned Today

Security Groups & NACLs

Concepts Covered

Security Group = instance-level, stateful, Allow-only, most permissive wins

NACL = subnet-level, stateless, Allow AND Deny, first match (number order) wins

Stateful = return traffic automatic. Stateless = you must allow BOTH directions.

Ephemeral ports 1024-65535 MUST be in NACL outbound rules for responses

Default NACL: allows ALL. Custom NACL: denies ALL (only * rule exists).

SG referencing: use another SG ID as source — better than IP addresses

One SG on many resources — all share rules instantly

SG: no explicit deny. To block an IP — use NACL Deny rule instead.

Troubleshoot: check BOTH SG AND NACL. Use VPC Flow Logs for ACCEPT/REJECT.

Traffic path: NACL inbound → SG inbound → Instance → SG out (auto) → NACL out

Before Next Class

1. Recall all 10 concepts without notes — active retrieval first
2. Console lab: create a custom Security Group, add inbound rules for HTTPS (443) and SSH from a specific CIDR only
3. Create a custom NACL on your private subnet — add inbound and outbound rules INCLUDING the ephemeral port range
4. Test: launch an EC2 in the private subnet, confirm the NACL blocks then allows traffic when you add rules
5. Write out the stateful vs stateless difference in your own words — 3 sentences
6. Re-read the 5 exam traps — especially the NACL evaluation ORDER trap
7. Post your NACL rule screenshot on the WhatsApp group — confirm ephemeral ports are included

Further Resources & Reading

Go deeper with these official AWS and industry resources:

Security Groups — Official AWS Documentation

OFFICIAL DOCS

<https://docs.aws.amazon.com/vpc/latest/userguide/vpc-security-groups.html>

Complete reference for Security Group rules, SG referencing between groups, default inbound/outbound behaviour, and the maximum rules per group. The Security group rules section covers all rule components including source/destination types.

Network ACLs — Official AWS Documentation

OFFICIAL DOCS

<https://docs.aws.amazon.com/vpc/latest/userguide/vpc-network-acls.html>

Complete reference for NACL rules, rule numbering, evaluation order, the difference between default and custom NACLs, and the ephemeral port ranges for different operating systems (Linux: 32768-60999, Windows: 49152-65535). Read the ephemeral ports section carefully.

VPC Flow Logs — Troubleshooting SG and NACL Issues

OPERATIONAL

<https://docs.aws.amazon.com/vpc/latest/userguide/flow-logs.html>

VPC Flow Logs show ACCEPT and REJECT decisions for every packet at both ENI and subnet levels. When traffic is not flowing and you cannot tell whether the SG or NACL is blocking it, Flow Logs give you the exact answer — REJECT at the subnet level = NACL. REJECT at the ENI level = Security Group.

AWS Security Hub — Foundational Security Best Practices for SGs

COMPLIANCE

<https://docs.aws.amazon.com/securityhub/latest/userguide/ec2-controls.html>

AWS Security Hub EC2 controls include automated checks for overly permissive Security Groups — specifically flagging any SG that allows unrestricted access (0.0.0.0/0) on high-risk ports like SSH (22), RDP (3389), and database ports. Enabling this gives you automatic detection of the most common SG misconfigurations.

SAA-C03 Domain 2 — Security Group & NACL Design

EXAM PREP

https://d1.awsstatic.com/training-and-certification/docs-sa-assoc/AWS-Certified-Solutions-Architect-Associate_Exam-Guide.pdf

Download the exam guide. Domain 2, Task Statement 2.2 covers designing secure network architectures. The stateful vs stateless distinction, NACL rule evaluation order, and Security Group referencing all appear in the task statement. These are guaranteed exam topics.

Homework: Read at least ONE resource above before next class. Post what you learned on the WhatsApp group.



Week 3 · Day 4 Complete

Security Groups & NACLs

Networking & VPC

Next: Hands-on Console Lab →

basestack.academy · Cohort 1 · AWS Cloud Accelerator